

프로젝트 기획안

클라우드 네이티브 환경의 침해 경로 자동 탐지와 CI/CD 재발 방지 체계 구축

작성일: 2026. 09. 04

팀원: 최준서, 안지명, 이하은

1. 프로젝트명

클라우드 네이티브 환경의 침해 경로 자동 탐지와 CI/CD 재발 방지 체계 구축

2. 프로젝트 개요

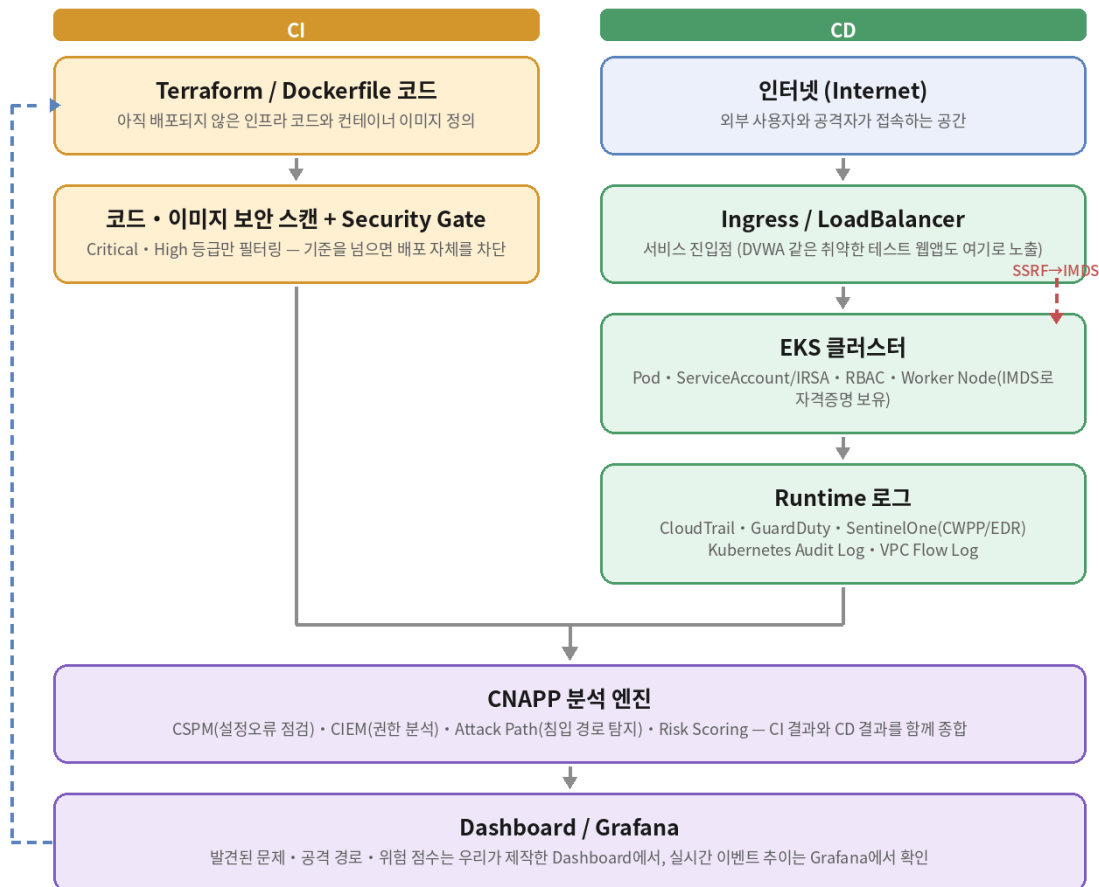
본 프로젝트는 AWS EKS(Elastic Kubernetes Service) 환경에서 발생할 수 있는 클러스터 설정 오류, Kubernetes RBAC 및 IAM(IRSA) 권한 관계를 하나의 흐름으로 연결하여, 공격자가 실제로 이동할 수 있는 공격 경로를 자동으로 식별하는 시스템을 구축한다. 식별된 공격 경로는 통제된 실험 환경에서 직접 검증하고, CloudTrail·GuardDuty·SentinelOne (CWPP/EDR) 등 실제 Runtime 로그를 통해 그 흔적을 확인한다. 보안 검증은 CI 단계(Terraform·Dockerfile 등 배포 전 코드·이미지 취약점 스캔)와 CD 단계(배포된 워크로드의 Runtime 취약점 탐지)로 나누어 진행하며, Critical·High 등급 위험을 우선적으로 다룬다. 최종적으로는 이 두 단계를 CI/CD 파이프라인으로 통합해 동일한 위험이 재발하지 않도록 자동으로 차단하는, 설정 → 탐지 → 대응 → 예방으로 이어지는 End-to-End 클라우드 네이티브 보안(CNAPP) 체계를 완성하는 것을 목표로 한다.

프로젝트는 하나의 통제된 CNAPP Lab 환경(AWS EKS 클러스터 기반)으로 구성되며, 모든 테스트는 팀이 직접 만든 Decoy 리소스만을 대상으로 한다.

3. 프로젝트 전체 구조

구조는 배포 전 CI 단계(Terraform·컨테이너 이미지 코드 보안 스캔)와 배포 후 CD 단계(Ingress로 노출된 서비스부터 EKS 클러스터 내부 Pod·RBAC·Node IAM Role, Runtime 로그까지)로 나뉘며, 두 단계의 결과를 CNAPP 분석 엔진이 함께 종합해 공격 경로를 자동으로 찾아낸다. 분석 결과는 Dashboard·Grafana로 시각화되고, 위험이 발견되면 다시 CI 단계에서 재검증하는 순환 구조다.

AWS EKS 기반 CNAPP 프로젝트 — 전체 구조



굵은 회색 화살표: 코드 작성부터 배포, 탐지, 분석까지 이어지는 정상 흐름

왼쪽 파란 점선: Dashboard에서 위험 발견되면 코드 수정해 다시 CI 단계부터 재검사하는 루프

오른쪽 빨간 점선: DVWA의 SSRF 취약점으로 Worker Node의 IMDS까지 도달하는 공격 경로 예시임 (OWASP Kubernetes Top 10 · K08)

4. 프로젝트 목적

- 컨테이너/쿠버네티스 환경에 특화된 보안 위험 요소(클러스터 설정 오류, RBAC 과다 권한, IRSA 권한 관계)를 연결하여, 실제로 침해 가능한 경로를 데이터 기반으로 증명한다.
- 이론적 취약점 분석에 그치지 않고, 통제된 환경에서 직접 공격을 재현하고 CloudTrail·SentinelOne 등 실제 로그로 검증하는 실증적 접근을 취한다.
- 탐지에서 끝나지 않고, IaC(Terraform)·CI/CD 파이프라인 단계에서 동일한 위험의 재발을 자동으로 차단하는 예방 체계까지 구현한다.
- 네트워크 보안, 클라우드 보안, 보안엔지니어링이라는 세 영역이 EKS라는 하나의 클라우드 네이티브 환경 안에서 어떻게 연결되는지 팀 프로젝트를 통해 체득한다.

5. 프로젝트 결과물 예시

- 클러스터 설정 오류 → RBAC·IRSA 권한을 연결한 공격 경로(Attack Path) 그래프 (OWASP Kubernetes Top 10 매핑 포함)
- EKS 네트워크 노출 분석 보고서 — NetworkPolicy 점검 결과, Ingress·LoadBalancer 노출 서비스 목록, VPC Flow Log 분석
- 해당 경로를 통제된 EKS 환경에서 재현하고 CloudTrail·SentinelOne(CWPP/EDR) 등 실제 로그로 검증한 증거 자료
- 보안 개선 전/후 위험 점수(Risk Score) 비교
- Terraform·Dockerfile 코드/이미지 스캔에서 Critical·High 위험이 발견되면 배포를 자동으로 차단하는 CI 보안 게이트 데모
- 공격 탐지 결과와 위험도를 한눈에 보여주는 대시보드 (자체 Dashboard + Grafana 모니터링)
- 최종 결과 보고서 및 발표 자료

6. 프로젝트 MVP 성공 기준

아래 최소 기준을 먼저 통과시킨 뒤, 여유가 되는 범위에서 확장한다.

항목	목표
CSPM Rule (AWS + EKS)	8~10개
IAM·RBAC 위험 패턴	4~6개
Attack Path (Controlled Attack, 시나리오 A/D 필수)	최소 2개
CI 코드/이미지 스캔 항목 (Terraform+Dockerfile, Critical·High)	최소 2개
CD Runtime 검증 Attack Path	최소 1개
CI Security Gate	1개 이상
Before / After Risk Score 비교	필수
Attack Graph	필수
Detection Matrix	필수
MITRE ATT&CK / OWASP K8s Top 10 Mapping	필수
Grafana 모니터링 대시보드	필수

7. 프로젝트 실행계획

선행관계를 기준으로 아래 4단계로 진행한다. 1단계(핵심 경로 구축)를 먼저 마친 뒤, 2단계부터는 역할별로 병렬 진행한다.

7.1 단계별 진행 계획

1. 핵심 경로 구축 — EKS 클러스터를 Terraform으로 생성하고, Pod → IRSA → IAM Role → S3 공격 경로와 DVWA(취약 웹앱)를 구성한다. (팀 전체 선행 작업)
2. 역할별 병렬 작업 — CI(코드·이미지 보안 스캔)와 CD(스캐너·로그 연동·모니터링)를 역할 별로 병렬 진행한다.
3. 공격 경로 연결 및 실제 검증 — Attack Path 엔진으로 경로를 자동 탐지하고, Controlled Attack 시나리오로 직접 재현하여 검증한다.
4. 자동화 및 개선 — CI Security Gate를 구축하고, 보안 개선 전/후 Risk Score 비교로 효과를 검증한다.

(참고) 프로젝트 완료 후에는 네이버클라우드(NCR·NKS) 등 다른 클라우드 환경으로 CNAPP 분석 로직을 확장하는 것을 향후 과제로 고려할 수 있으며, 현재 실행계획의 범위에는 포함하지 않는다.

7.2 공격 경로 검증 시나리오 (Controlled Attack)

아래 시나리오는 팀이 구성한 CNAPP Lab(EKS) 환경 안에서만 재현하며, 테스트에 사용하는 자산과 데이터는 모두 프로젝트용으로 별도 생성한 Decoy 리소스로 한정한다.

우선순위	시나리오	공격 경로	검증 절차 요약
1순위(필수)	노출된 Pod → 클라우드 자산 접근(OWASP K01)	Public Pod(Ingress 노출) → ServiceAccount(IRSA) → IAM Role → Sensitive S3	Pod 내부에서 ServiceAccount 토큰으로 임시 자격증명 획득 → AssumeRoleWithWebIdentity → S3 접근. CloudTrail에서 AssumeRoleWithWebIdentity·GetObject 이벤트 확인, SentinelOne에서 Pod 내 프로세스·명령 실행 탐지 여부 확인
2순위(필수·신규)	DVWA(웹 취약점) → IMDS 자격증명 탈취(OWASP K08)	DVWA(SSRF 취약점 웹앱) Pod → Worker Node IMDS(169.254.169.254) → Node IAM Role 임시 자격증명 → 클라우드 자원 접근	DVWA의 SSRF 기능으로 Node IMDS에 요청을 보내 IAM 자격증명을 획득 → 획득한 키로 AWS CLI 호출 성공 여부 확인. CloudTrail에서 비정상 위치의 API 호출 이벤트 확인, SentinelOne에서 Pod의 비정상 아웃바운드 요청 탐지 여부 확인
3순위(권장)	RBAC 권한 상승(OWASP K02)	낮은 권한 Pod → 과도한 ClusterRoleBinding → Kubernetes Secret(AWS 자격증명) → LabAdminRole	과도한 RBAC 권한으로 다른 네임스페이스의 Secret을 조회해 AWS 자격증명을 탈취하고 API를 호출. Kubernetes Audit Log 및 CloudTrail에서 이벤트 확인